

ISMS Roles & Responsibilities Register

Role	ISMS Responsibilities
Board of Directors	Approve risk appetite; hold executive leadership accountable for ISMS effectiveness
CEO	Approve the Information Security Policy; sponsor the ISMS at the executive level
CISO	Own the ISMS; accountable for its overall effectiveness and reporting to the Risk Committee
GRC Manager	Manage day-to-day ISMS implementation; maintain the risk register; oversee ISMS documentation and compliance activities
Risk Committee	Review and approve risk treatment decisions within the Board-approved risk appetite
IT Operations	Implement and maintain technical security controls; monitor system security; report control status
HR	Manage secure onboarding and offboarding processes; coordinate security awareness training
Legal	Interpret regulatory obligations; review customer and vendor contract security requirements
Department Managers	Enforce information security policies within their teams; identify and escalate security risks and incidents
Employees	Follow security policies and standards; complete mandatory training; report suspicious activity and security incidents
Third-Party Vendors	Meet contractual security obligations; participate in vendor security assessments and audits